# DATABASE SECURITY

NT534 – An toàn mạng máy tính nâng cao

GV: Đỗ Thị Phương Uyên - uyendtp@uit.edu.vn

Nguyễn Duy – duyn@uit.edu.vn


# Nội dung

**Hôm nay học gì?**

1. What is Database Security?
2. What is Database Security Technical?
3. How to deploy DBF?

# What is Database Security?

- There are four key issues in the security of databases, just as with all security systems:
- ➢ Confidentiality
- ➢ Integrity
- ➢ Authenticity
- ➢ Availability

# What is Database Security?

## Confidentiality

- Need to ensure that **confidential data** is only available to correct people
- Need to ensure that entire database is **security from external and internal system breaches**
- Need to provide for **reporting** on who has accessed what data and what they have done with it
- Mission critical and Legal sensitive data must be highly security at **the potential risk of lost business and litigation**

# What is Database Security?

## Integrity

- Need to verify that any external data has the correct formatting and other metadata
- Need to verify that all input data is accurate and verifiable
- Need to ensure that data is following the correct work flow rules for your institution/corporation
- Need to be able to report on all data changes and who authored them to ensure compliance with corporate rules and privacy laws.

# What is Database Security?

## Authenticity

- Need to ensure that the data has been edited by an authorized source
- Need to confirm that users accessing the system are who they say they are
- Need to verify that any outbound data is going to the expected receiver
- Need to verify that all report requests are from authorized users

# What is Database Security?

## Availability

- Data needs to be available at all necessary times
- Data needs to be available to only the appropriate users
- Need to be able to track who has access to and who has accessed what data

# What is Database Security?

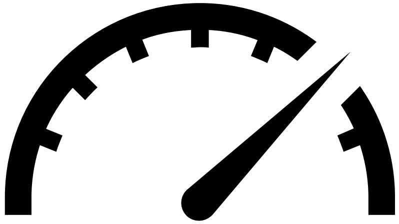
## Security for Database

- Design Database: architecture, encrypt,….
- Security functions of Database: Oracle, Microsoft,…
- 3rd security option: Database Firewall,…

# What is Database Security Technical?

## Technical Solution

- Access Control
  - Management of Logins and Roles to restrict access of data
  - Prevent unauthorized persons from obtaining sensitive information
- Data Encryption
  - Obfuscating Data using key-based cryptography, or obscuring data with alternate text
  - Ensure data is only legible to the intended audience
- Proactive Monitoring
  - Detailed logging of failed authentication attempts for use in access auditing, as well as raise alerts on anomalous activity which may indicate a security threat



# What is Database Security Technical?

## Access Control

- Identification – Are you allowed?
- Authentication – Who are you?
- Authorization – What all could you do?

# What is Database Security Technical?

## Firewall

- Protects network and its resources from malicious external users
- Secure confidential information from those who do not have "explicit" access to it
- Firewall settings enable administrators to determine conditions for which a connection to the server instance is allowed
- Windows authentication in SQL Server provides centralized access control with Active Directory

# What is Database Security Technical?

## AD Authentication

- Secure access to on-premises and cloud applications, including Microsoft online services like Office 365 and many non-Microsoft SaaS applications
- Extend to Azure Active Directory on cloud for simplified user access
- User attributes along with roles and access permissions are automatically synchronized to cloud directory
- Every organization resource request is validated to ensures only authenticated users connects to that resource
- Avoid using SQL Authentication

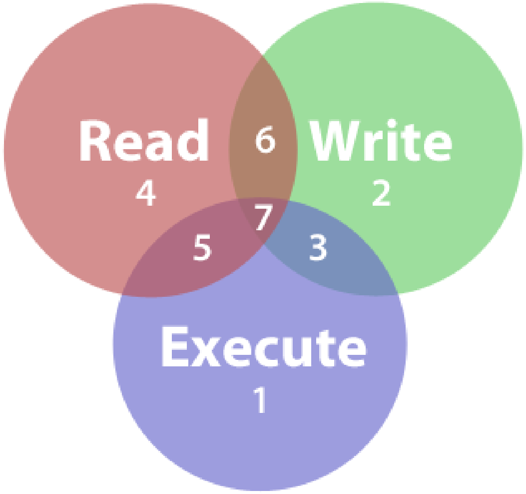
# What is Database Security Technical?

## Separation of Roles

- Not every authenticated user should access everything. Only authorized users should get access to any resource/ data.
- Role-based access control (RBAC) is an approach to restricting system access to authorized users.
- Permissions are associated with roles, and users are assigned to appropriate roles
- Roles are created for the various job functions in an organization and users are assigned roles based on their responsibilities and qualifications.
- Users can be easily reassigned from one role to another

# What is Database Security Technical?

## Permission

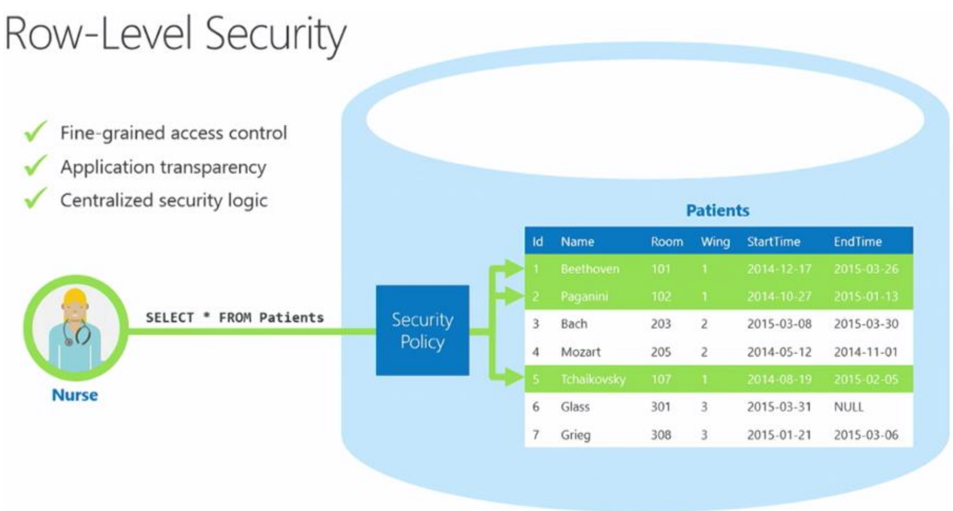



- Granular access permissions for the organization's repositories
- Admin must ensure that minimum required permissions are given to any role/user to allow it complete the required tasks. No less and No more
- Read, Write and Execute – Ensure right user have right set of permissions, to avoid any malicious or accidental threat to data security.
- Regular audit of permissions must be done.

# What is Database Security Technical?

## Row-Level Security

- RLS enables storing data for many users in a single database and table while ensuring user sees only her/his data
- Access is restricted to row-level, and based on a user’s identity, role, and / or execution context
- Access logic  is centralized
- Reduced risk of error in application code

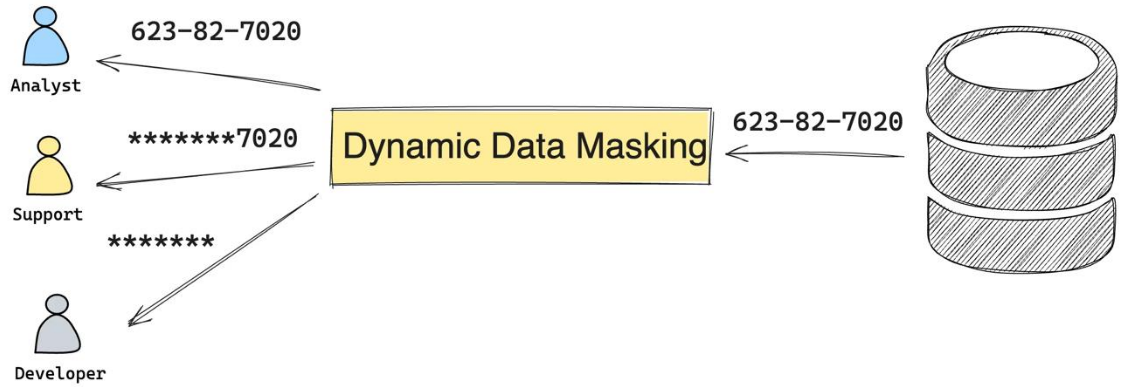



| Id | Name | Room | Wing | StartTime | EndTime |
|---|---|---|---|---|---|
| 1 | Beethoven | 101 | 1 | 2014-12-17 | 2015-03-26 |
| 2 | Paganini | 102 | 1 | 2014-10-27 | 2015-01-13 |
| 3 | Bach | 203 | 2 | 2015-03-08 | 2015-03-30 |
| 4 | Mozart | 205 | 2 | 2014-05-12 | 2014-11-01 |
| 5 | Tchaikovsky | 107 | 1 | 2014-08-19 | 2015-02-05 |
| 6 | Glass | 301 | 3 | 2015-03-31 | NULL |
| 7 | Grieg | 308 | 3 | 2015-01-21 | 2015-03-06 |

# What is Database Security Technical?

## Dynamic Data Masking

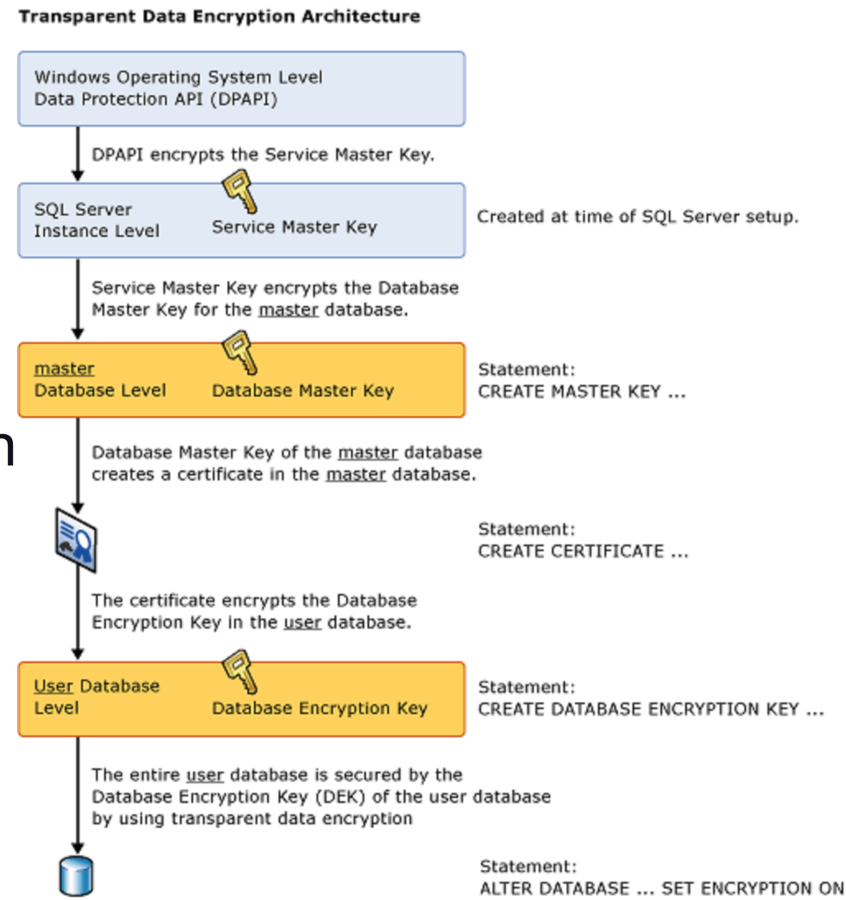
- Protects against unauthorized disclosure of sensitive data in the application
- Protect personally identifiable information
- Regulatory Compliance
- Expose sensitive data only on a need-to-know basis
- In absence of this typically Custom obfuscation in application, views or third party solutions are used to address this need



# What is Database Security Technical?

## Encryption – Transparent Data Encryption

- Data protected “at rest”
- Encryption/Decryption is transparent to application – no changes to code required
- Does not require schema modification during implementation
- Azure Services auto-manages server certificates and encryptions keys – rotates every 90 days by Microsoft



# What is Database Security Technical?

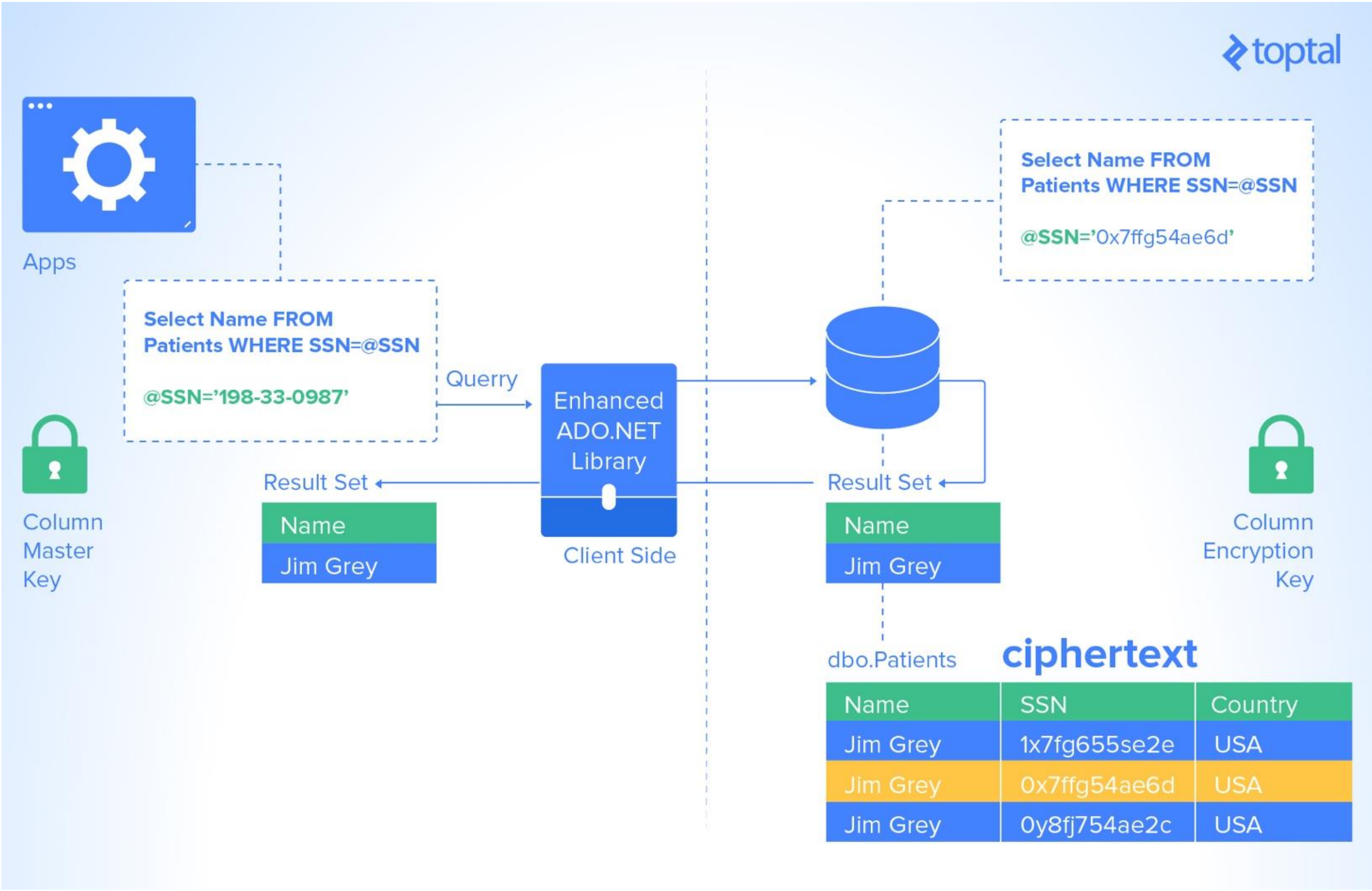
## Encryption – The need for Always Encrypted

- Data disclosure prevention
  - Client-side encryption of sensitive data using keys that are never given to the database system
- Queries on encrypted data
  - Support for equality comparison, including join, group by, and distinct operators
- Application transparency
  - Minimal application changes via server and client library enhancements

Allows customers to securely store sensitive data outside of their trust boundary. Data remains protected from high-privileged, yet unauthorized, users.

# What is Database Security Technical?

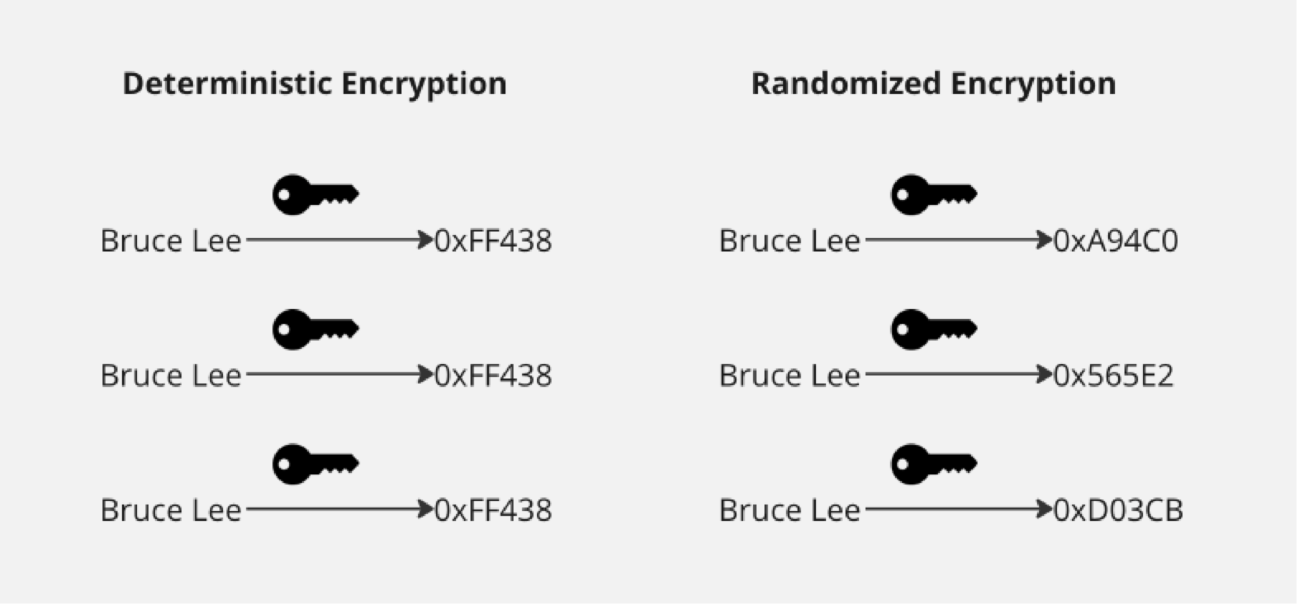
## Encryption – Always Encrypted Setup



# What is Database Security Technical?

## Encryption – Types of encryption

- Randomized encryption: uses a method that encrypts data in a less predictable manner
- Deterministic encryption: uses a method that always generates the same encrypted value for any given plaintext value



# What is Database Security Technical?

## Proactive Monitoring - Sensitive Data Auditing

- A multinational oil & gas company needed to:
  - Streamline database auditing for PCI and SOX
  - Reduce time and log collection errors
  - Send activity alerts to Security Information Event Manager (SIEM)
- SecureSphere DAM:
  - Capture audit details generate reports
  - Generate SIEM alerts

# What is Database Security Technical?

## Proactive Monitoring - Sensitive Data Auditing

### Reporting

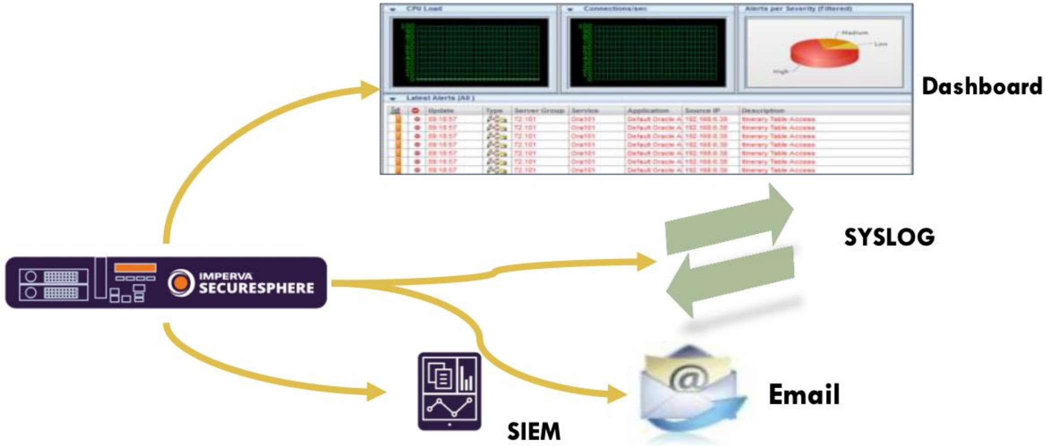
**Enterprise class reporting framework**

- Analyze threats
- Accelerate compliance


### Alerting

**Alert in real time on suspicious behavior**

- Quickly identify attacks
- Prevent data theft



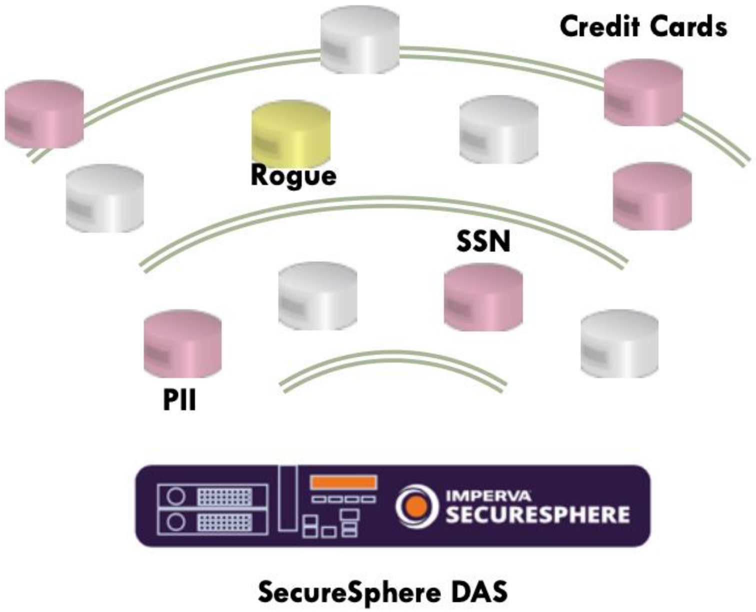
# What is Database Security Technical?

## Proactive Monitoring - Sensitive Data Auditing

**Discovery & Classification**

**Discover DBs and classify sensitive information**

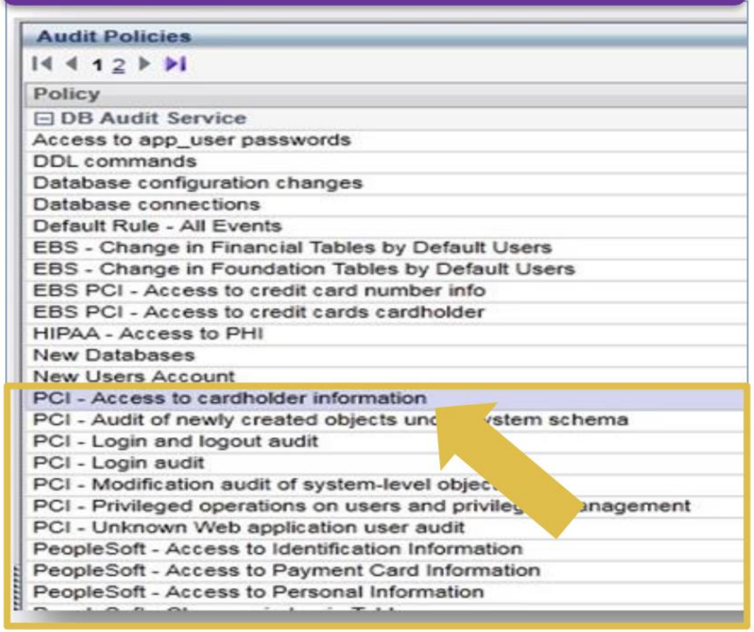
- Discover active DB services
- Identify rogue DBs
- Determine what needs to be monitored



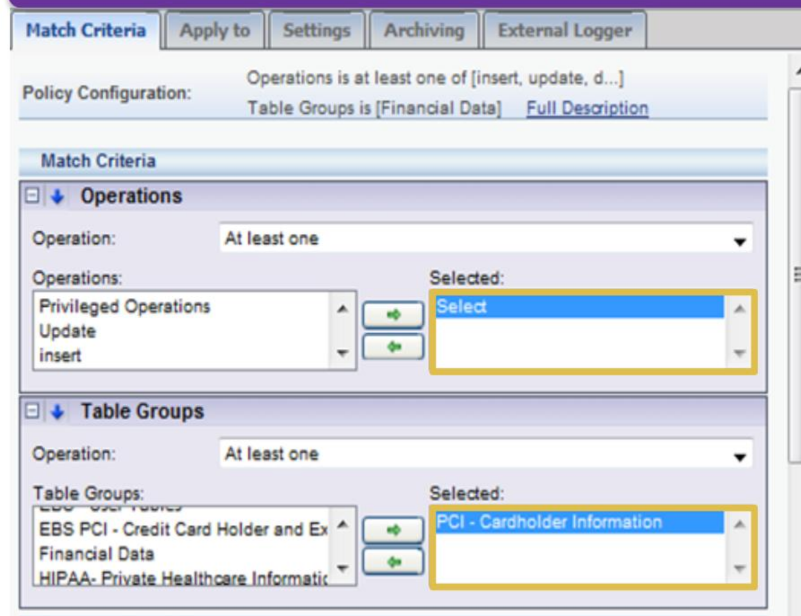
# What is Database Security Technical?

## Proactive Monitoring – Audit Access to Cardholder Information

**Pre-defined PCI Audit Policies**




**SELECT Operations on Cardholder Data**



# What is Database Security Technical?

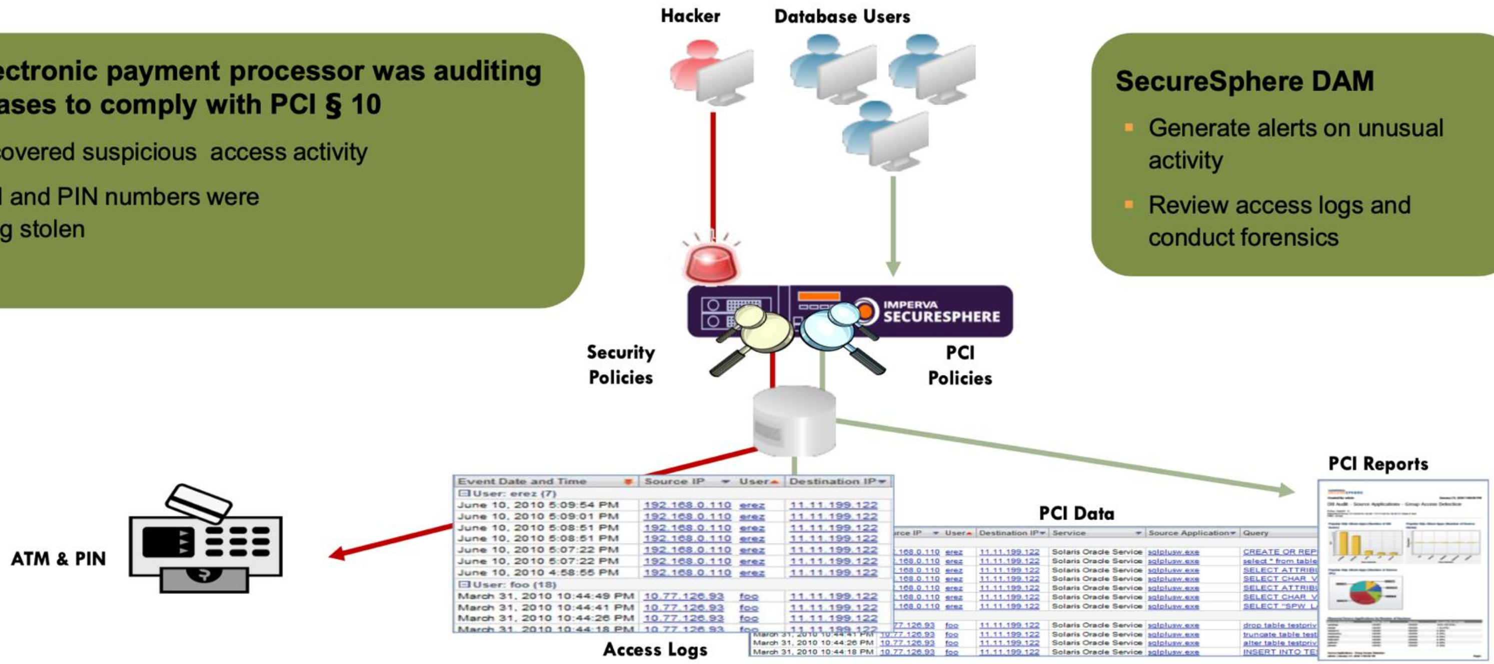
## Proactive Monitoring – Data Theft Prevention

**An electronic payment processor was auditing databases to comply with PCI § 10**

- Discovered suspicious access activity
- ATM and PIN numbers were being stolen

**SecureSphere DAM**

- Generate alerts on unusual activity
- Review access logs and conduct forensics



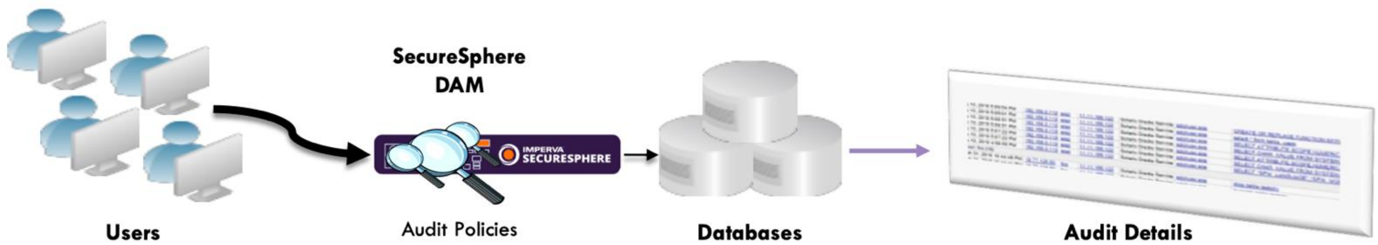
# What is Database Security Technical?

## Proactive Monitoring – Data Theft Protection

### Activity Auditing

**Collect and record database activity details**

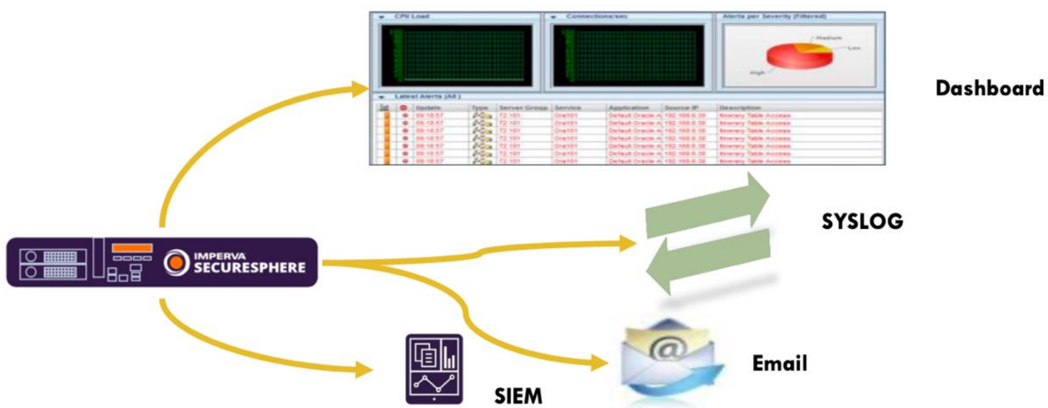
- Satisfy compliance requirements
- Conduct forensic analysis
- Generate alerts




### Alerting

**Alert in real time on suspicious behavior**

- Quickly identify attacks
- Prevent data theft



# What is Database Security Technical?

## Proactive Monitoring – Data Theft Protection

### Analytics

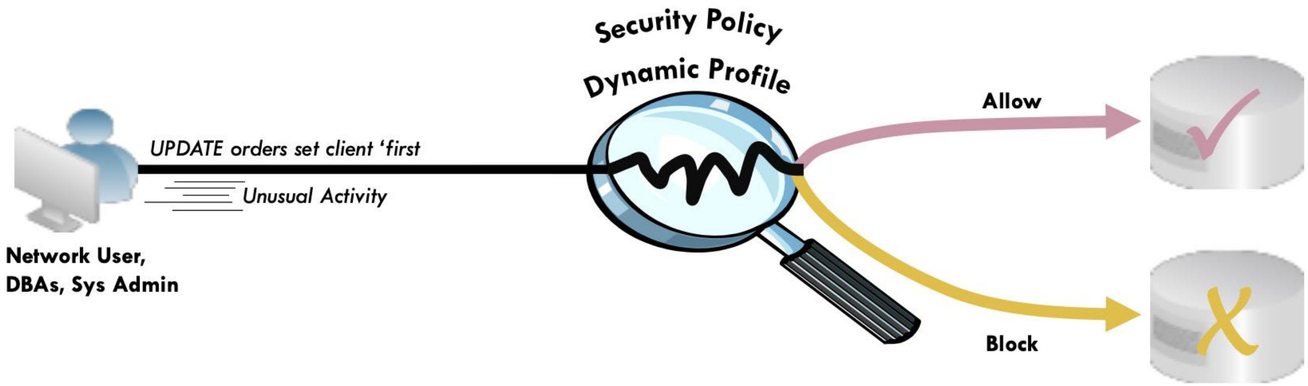
**Examine detailed audit logs, interactive dashboard views, and reports**

- Accelerate forensic analysis
- Simplify compliance


### Blocking

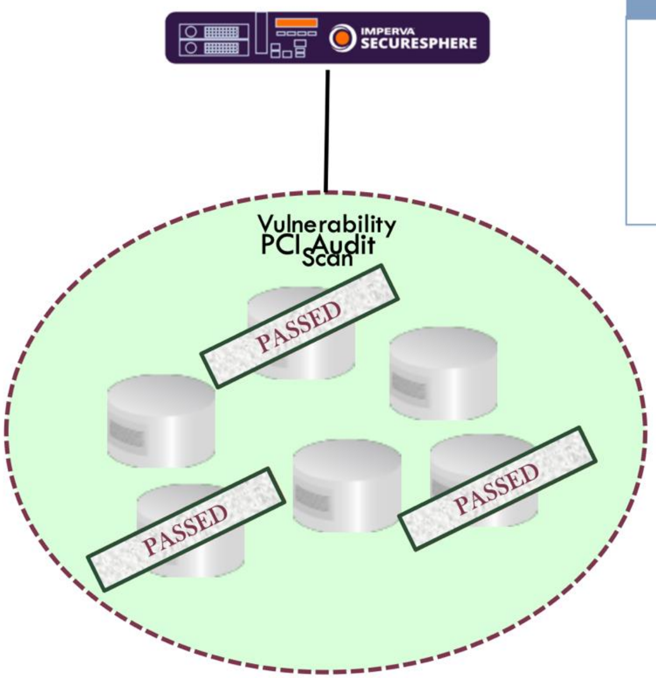
**Monitor database access**

- Prevent unauthorized database access
- Secure sensitive data



# What is Database Security Technical?

## Proactive Monitoring – Database Vulnerability





**An online retailer failed PCI and internal audits:**

- PCI 6.1 required quarterly audits
- 300 databases in scope
- Patching was time consuming and disruptive

**SecureSphere DAS:**

- Database vulnerability scans
- Identify missing patches
- Reduce audit activity to 2 times per year

# What is Database Security Technical?

## Proactive Monitoring – Database Vulnerability

**Vulnerability Scanning & Patching**

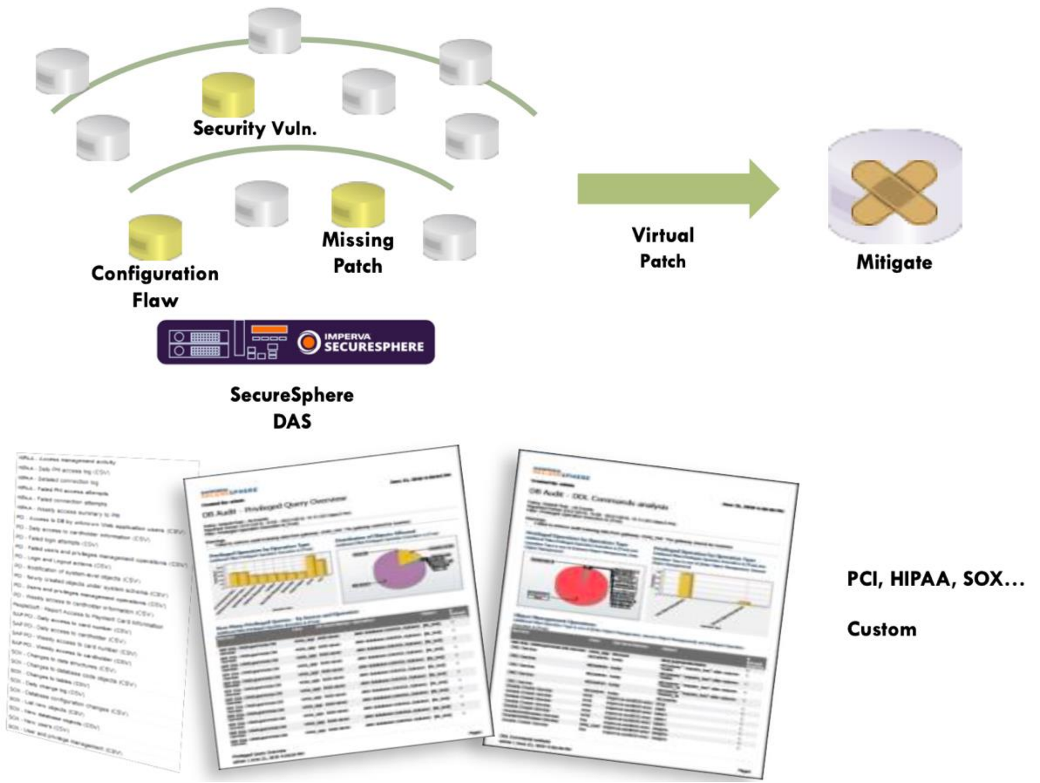
**Identify and mitigate security vulnerabilities and config. flaws**

- Automate vulnerability assessment, remediation and verification process

**Reporting**

**Enterprise class reporting framework**

- Analyze threats
- Accelerate compliance



# Câu hỏi/thắc mắc nếu có?

Giới thiệu môn học

Today end,
**See you next week!**